

# Code Quality Report — Tick & Taka (round 3)

Bun monorepo: Hono API, Expo Android app, shared package

|                   |                                                                                                                                                                                                               |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Project           | Tick & Taka ( tick-taka )                                                                                                                                                                                     |
| Date              | 2026-10-07                                                                                                                                                                                                    |
| Commit            | 7e2bfeb (branch fix/audit-2026-10-06)                                                                                                                                                                         |
| Previous audits   | Round 1 at 3b5438b : 70/100. Round 2 at df29d67 : 72/100, 16 open findings. 42 commits since round 2.                                                                                                         |
| Auditor role      | Staff Engineer (architecture, maintainability, security, performance)                                                                                                                                         |
| Companion reports | QA_Report.pdf and UX_Report.pdf, written in parallel by other auditors                                                                                                                                        |
| Mode              | Read-only. No source, config, dependency or git state was changed. Scan and probe scripts ran from a scratch folder inside docs/audit/2026-10-07-r3/ against in-memory databases and were deleted afterwards. |

# 1. Executive summary

83

/ 100

R1 70 · R2 72

The 42 commits did what they said. I re-checked all 16 open round-2 findings against the code: 13 are fixed, 3 are partly fixed, none were left alone and none regressed. The API can no longer be taken down by a bad time zone. A token refresh no longer signs the phone out. A Keystore read failure no longer deletes the queued writes. CHECK violations come back as 400s, and a write the server keeps failing on is set aside instead of blocking the queue. All four have tests that exercise the failure, and the non-null-assertion rule is now an error with zero uses in source.

The fresh review found one High. The phone learns the server's clock from an `x-server-time` header, and when a reply has no header (any page Nginx writes itself, such as the 502 shown during every `pm2 restart`) the code reads it as time 0. The phone's edit stamps then start again from 1 January 1970. Edits tapped before the next normal reply lose last-write-wins on the server and vanish without a message. I reproduced both halves. The fix is two lines. The new stuck-write parking also lets dependent writes run ahead of the create they depend on (Medium). The other eight findings are Low.

| Severity (open findings) | Count                 | Round-2 status  | Count |
|--------------------------|-----------------------|-----------------|-------|
| Critical                 | 0                     | Fixed           | 13    |
| High                     | 1                     | Partially fixed | 3     |
| Medium                   | 1                     | Not fixed       | 0     |
| Low                      | 8                     | Regressed       | 0     |
| Total                    | 10 (7 new, 3 carried) |                 |       |

## Top 5 issues to fix first

| ID     | Severity | Issue                                                                                                                                                                                          |
|--------|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CQ-036 | High     | A reply without <code>x-server-time</code> sets the phone's edit clock to 1970. Edits made until the next normal reply are dropped by last-write-wins or refused (reproduced). Effort S.       |
| CQ-038 | Medium   | Parking a stuck create lets later edits and deletes of the same record go first. They are dropped as 404s, and Retry brings the record back without them.                                      |
| CQ-039 | Low      | Outbox save failures are swallowed. The widget hand-over deletes its durable copy while the queue may be held only in memory.                                                                  |
| CQ-037 | Low      | A Keystore read failure at start still makes TanStack delete the encrypted cache, and the next save can land in plain text.                                                                    |
| CQ-042 | Low      | The new tests pass inputs the real code never passes: NaN instead of <code>Number(null)</code> , and an unrelated write behind a stuck one. That gap is how CQ-036 and CQ-038 slipped through. |

## 2. Scorecard

| Area                          | R1 | R2 | R3 | Justification                                                                                                                                                                                                                                                                                                                                                                     |
|-------------------------------|----|----|----|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Architecture                  | 8  | 8  | 8  | Splits were made along real seams: the assistant's <code>act</code> cases now sit in a handler table ( <code>actions.ts</code> ), and bulk moves live in <code>tasks/bulk-move.ts</code> . AI totals moved to <code>users.db</code> , so no request opens other users' databases. The one lazy import cycle is still there ( <code>time.ts</code> ↔ <code>money.ts</code> ).      |
| Readability & maintainability | 7  | 7  | 8  | No file is over 800 lines, there are 0 TODOs, and the two big API closures shrank by about a third. <code>quick-add.ts</code> grew to 649 lines. A 20-line month stepper is pasted in 3 screens, against the owner's rule (CQ-040). Two doc comments were orphaned by edits.                                                                                                      |
| Type safety                   | 8  | 7  | 8  | Non-null <code>!</code> went from 60 to 0 and the rule is an error. A <code>defined()</code> helper is used at 16 sites, there is 1 <code>any</code> and 0 <code>@ts-ignore</code> . <code>timeZone</code> is validated at the boundary. Client JSON is still cast without checks (CQ-022), and the clock reads a header with <code>Number()</code> without checking it (CQ-036). |
| Error handling                | 5  | 6  | 8  | Each user's job run is isolated, ticks are caught, and unhandled rejections are logged. CHECK and NOT NULL violations map to 400. A missing key is told apart from a wrong one. Outbox save failures are still swallowed (CQ-039).                                                                                                                                                |
| Security                      | 6  | 6  | 8  | The one-request DoS is gone. Pre-session tokens stop on 7 Nov 2026, refresh has a bounded 60 s grace, and the live TLS and HSTS config is in the repo. Left: a plain-text fallback for the cache (CQ-037) and 5 accepted tooling advisories.                                                                                                                                      |
| Performance                   | 6  | 8  | 9  | <code>/sync/changes</code> is capped per table and has a counts-only mode. The usage report reads one table. A refreshed session runs an UPDATE on every request (CQ-041), which is cheap.                                                                                                                                                                                        |
| Data layer & sync integrity   | 7  | 8  | 7  | Migration 0004 repairs bad rows before the rebuild, and a failure to open is logged with the user's tag. Offset to that, the sync path now has a silent-loss bug (CQ-036) and an ordering hole (CQ-038), both in this round's new code.                                                                                                                                           |
| Tooling & DX                  | 6  | 8  | 8  | Biome, typecheck and 689 tests are green, and CI runs them. All 42 commits are Conventional Commits with no attribution lines. The audit job is always red, so it can't flag a new advisory (CQ-012). One README line promises more undo than the code gives.                                                                                                                     |
| Testing                       | 6  | 7  | 8  | 568 tests became 689. The glue round 2 named is now tested: session manager, job loop, key-unavailable and stuck writes. Some of those tests use idealised inputs (CQ-042). <code>ai/ask.ts</code> is at 62.7% lines.                                                                                                                                                             |
| Dependencies                  | 7  | 7  | 8  | <code>uuid</code> is pinned to 11.1.1 through <code>overrides</code> . The other 5 advisories are accepted with a reason each in the README. Bun is pinned and installs use a frozen lockfile.                                                                                                                                                                                    |

The overall score is a weighted judgement, not an average. Security, error handling and data integrity count double because the app holds personal finance records. With no Critical left, the score rises a long way. The new High in the offline sync path caps it in the low 80s. With CQ-036 and CQ-038 fixed, the codebase would be close to 90.

## 3. Scope & method

### What was reviewed

- Every round-2 open finding, re-checked line by line at 7e2bfeb (section 4).
- Everything changed in `git diff df29d67..HEAD` (216 files, +5,273/-1,283): time-zone validation and `jobs/scheduler.ts`; `db/sessions.ts` and refresh grace; `middleware/error-handler.ts`; `outbox-queue.ts`/`outbox-policy.ts` stuck writes; `encrypted-storage.ts`/`secure-storage.ts`; migration 0004 repair; `db/usage-totals.ts`; `LEGACY_TOKENS_UNTIL`; `/sync/changes` limit and summary; `jobs/offsite.ts`; `assistant/actions.ts`, `records.ts`; `tasks/bulk-move.ts`; `shared/defined.ts` and `biome.json`; the uuid override; `deploy/nginx-tick-taka.conf`; `phone-writes.ts`; `server-clock.ts`; `session-manager.ts`; widget hand-over.
- Whole-repo scans: file and function sizes (TypeScript AST), type-safety counts (AST), import cycles (Tarjan SCC over 411 files), duplicated 8-line blocks, exports referenced nowhere, `console.*`, swallowed catches, TODOs, committed secrets.
- Yardstick: README.md, PRODUCT.md, docs/IMPLEMENTATION\_PLAN.md, the spec (`_raw/spec.txt`), the round-2 report, and the owner's rules: 800-line ceiling, no barrel files, strict TypeScript, Conventional Commits, shared component for markup repeated in 3+ files.

### Commands run

| Command                                          | Result                                                                                                                                                     |
|--------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>bunx biome check .</code>                  | 523 files, 0 diagnostics, exit 0 ( <code>_raw/lint.txt</code> )                                                                                            |
| <code>bun run typecheck</code>                   | shared, api, mobile: exit 0                                                                                                                                |
| <code>bun run test</code>                        | shared 247, mobile 233, api 209 pass; 0 fail (689 total)                                                                                                   |
| <code>bun test --coverage per workspace</code>   | api 94.49% lines / 88.18% funcs; shared 96.50 / 82.95; mobile 93.79 / 93.47                                                                                |
| <code>bun audit</code>                           | 5 advisories (2 high, 3 moderate), exit 1                                                                                                                  |
| <code>bunx expo export --platform android</code> | Bundles OK: 2,837 modules, 7.7 MB Hermes bytecode                                                                                                          |
| AST scan (TypeScript compiler API)               | 144 <code>as</code> casts, 95 <code>as const</code> , 0 non-null <code>!</code> , 1 <code>any</code> ; function sizes in Appendix C                        |
| Import-graph SCC                                 | 1 cycle: <code>db/schema/time.ts</code> ↔ <code>db/schema/money.ts</code>                                                                                  |
| Probe <code>probe-clock.ts</code> (Appendix G)   | Reproduced CQ-036 on the phone side:<br><code>editTime()</code> = -50 (1969-12-31T23:59:59.950Z)<br>after a header-less reply, and the bad offset is saved |

| Command                                                                       | Result                                                                                                                                                             |
|-------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Probe <code>probe-lww.test.ts</code> against <code>createTestContext()</code> | Reproduced CQ-036 on the server side: PATCH with <code>updatedAt: 60000</code> → 200 with the old title; with <code>-50</code> → 400 <code>validation_error</code> |

## Not verified

**Unverified** No device run. The emulator image has no Google Play services, and sign-in is Google-only. How often Keystore reads fail on a real phone (CQ-037) and how often a phone receives an Nginx error page (CQ-036) could not be measured.

**Unverified** The production server: whether `.env` sets `TRUST_PROXY=true` and `BACKUP_OFFSITE_CMD`, whether the installed Nginx site matches `deploy/nginx-tick-taka.conf`, and whether production databases had rows that the new 0004 repair statements changed.

**Unverified** I did not run `bun outdated`, which needs the network. Nor could I check the README's claim that `braces` and `node-forge` have no patched release, or whether `bun audit 1.3.11` supports an ignore list or JSON output (CQ-012).

## 4. Previous findings status (round 2 → round 3)

Each row was checked against the code at `7e2bfeb`. Line numbers refer to `7e2bfeb`.

| ID     | Round-2 finding                                                                  | Status | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|--------|----------------------------------------------------------------------------------|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CQ-027 | Invalid time zone crashes the API in a restart loop<br><b>Critical</b>           | Fixed  | <code>timeZone</code> is refined with <code>isTimeZone</code> ( <code>shared/schemas/settings.ts:25</code> ). <code>readSettings</code> drops a bad stored value field by field ( <code>settings/service.ts:12-24</code> ), and <code>safeTimeZone</code> guards both <code>userTimes</code> . <code>runJobsFor</code> runs each user inside try/catch ( <code>scheduler.ts:83-95</code> ), the tick catches ( <code>:110-114</code> ), and <code>installCrashLogging</code> logs unhandled rejections ( <code>log.ts:44-52</code> , <code>index.ts:11</code> ). Tests: <code>time-zone.test.ts</code> , <code>jobs.test.ts:38-131</code> . |
| CQ-029 | Refresh revokes old token at once; concurrent 401 signs out<br><b>Medium</b>     | Fixed  | Refresh no longer revokes. The replaced session retires 60 s after the new one is first used ( <code>sessions.ts:44</code> , <code>101-112</code> ), and logout ends both. The phone switches tokens in memory before writing SecureStore and waits for an in-flight refresh before expiring ( <code>session-manager.ts:66-76</code> , <code>95-105</code> ). <code>event-stream.ts:41</code> passes the token it sent. Tests: <code>sessions.test.ts:36-95</code> , <code>session-manager.test.ts:89-115</code> .                                                                                                                          |
| CQ-028 | Encrypted storage deletes the queue when the key can't be read<br><b>Medium</b>  | Fixed  | <code>KeyUnavailableError</code> is rethrown and the sealed value is kept. A value the loaded key can't open is moved to <code>.unreadable</code> , never deleted ( <code>encrypted-storage.ts:57-69</code> ). The background re-seal race is gone. <code>OutboxQueue.load</code> marks itself unreadable and never saves over the stored queue ( <code>outbox-queue.ts:135-150</code> , <code>320-322</code> ). Tests: <code>encrypted-storage.test.ts:65-95</code> , <code>outbox-queue.test.ts:260</code> . The cache path still has a gap (new CQ-037).                                                                                 |
| CQ-030 | CHECK violations are 500; a 5xx write blocks the outbox forever<br><b>Medium</b> | Fixed  | CHECK and NOT NULL map to 400 <code>invalid_data</code> and are logged ( <code>error-handler.ts:27-37</code> ). The event PATCH checks its range against the stored row ( <code>events/routes.ts:39-41</code> ). After 8 server faults (not 503) a write is parked, and the sync bar offers Retry and Discard ( <code>outbox-queue.ts:247-254</code> , <code>sync-status.tsx:46-52</code> ). Tests: <code>logging.test.ts:88</code> , <code>constraints.test.ts</code> , <code>outbox-queue.test.ts:290-351</code> . Parking introduced an ordering issue (new CQ-038).                                                                     |
| CQ-031 | Deleted account recreated by the job run<br><b>Low</b>                           | Fixed  | The user is re-checked after each yield ( <code>scheduler.ts:86</code> ), and <code>data()</code> refuses a user with no registry row ( <code>user-registry.ts:181</code> ). Tests: <code>jobs.test.ts:94-123</code> .                                                                                                                                                                                                                                                                                                                                                                                                                      |

| ID     | Round-2 finding                                                                     | Status                               | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|--------|-------------------------------------------------------------------------------------|--------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CQ-032 | No clean-up for rows that break the new CHECKS <span>Low</span>                     | Fixed                                | 43 repair statements run before the rebuild ( <code>0004_constraints.sql:8-56</code> ). A failed open is logged with the user's tag ( <code>user-registry.ts:184-193</code> ). Test: <code>migrations.test.ts:133</code> . The fix edits a migration that has already shipped. That is safe here because drizzle's SQLite migrator compares timestamps, not hashes, and the file's comment says so.                                         |
| CQ-034 | Usage report opens every user's database <span>Low</span>                           | Fixed                                | <code>ai_usage_totals</code> in <code>users.db</code> ( <code>db/usage-totals.ts</code> ) is incremented on each logged call ( <code>ai/usage.ts:57-65</code> ) and recounted nightly ( <code>scheduler.ts:22-29</code> ). The report reads only that table ( <code>usage-report.ts:68-84</code> ).                                                                                                                                         |
| CQ-033 | Pre-session tokens can't be revoked <span>Low</span>                                | Fixed                                | Tokens without a <code>jti</code> are refused from <code>LEGACY_TOKENS_UNTIL = 7 Nov 2026</code> , and the constant carries a dated note to remove the branch ( <code>middleware/auth.ts:15-21, 41-42</code> ). Test: <code>sessions.test.ts:169</code> .                                                                                                                                                                                   |
| CQ-019 | Off-site backups depend on a manual cron <span>Low</span>                           | Fixed <span>server Unverified</span> | <code>BACKUP_OFFSITE_CMD</code> ( <code>env.ts:25</code> ) runs once after any tick that wrote a backup ( <code>scheduler.ts:96-98</code> ). It never throws, times out after 10 min and logs stderr ( <code>jobs/offsite.ts, 96% lines covered</code> ). The README example is a plain <code>rsync --delete mirror</code> , so copies sit unencrypted on the other host. That is acceptable for a host the owner controls.                 |
| CQ-016 | <code>/sync/change</code> s unbounded <span>Low</span>                              | Fixed                                | Each table is capped at <code>limit</code> (1–1000, default 500), with <code>more</code> ( <code>sync/routes.ts:25-42, schemas/common.ts:42-46</code> ). <code>summary=true</code> returns counts only ( <code>:48-62</code> ), and <code>pullChanges</code> uses it ( <code>sync-changes.ts:54</code> ). Turn recovery refreshes everything when <code>more</code> is set ( <code>recover-turn.ts:49-51</code> ).                          |
| CQ-020 | <code>taskService</code> and <code>createToolRunner</code> growing <span>Low</span> | Partially fixed                      | <code>createToolRunner</code> went from 342 to 210 lines: its act cases moved to <code>ACTION_HANDLERS</code> ( <code>actions.ts, 222 lines</code> ) and helpers to <code>records.ts</code> . <code>taskService</code> went from 378 to 263, with bulk moves in <code>bulk-move.ts</code> . <code>actions.ts</code> is at 96% lines. But <code>shared/quick-add.ts</code> , named in the same finding, grew from 583 to 649 lines. Carried. |

| ID     | Round-2 finding                                             | Status                  | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                            |
|--------|-------------------------------------------------------------|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CQ-022 | Non-null assertions allowed; client JSON cast<br><b>Low</b> | Partially fixed         | <code>noNonNullAssertion: "error"</code> outside tests ( <code>biome.json:30, 64</code> ). <code>!</code> went from 60 to 0 in source, via type guards ( <code>planning.ts:43-45</code> , <code>today/service.ts:101</code> ) and <code>defined()</code> at 16 sites. <code>api.ts:52, 69</code> still cast server JSON, and the persister <code>buster</code> is still <code>"1"</code> ( <code>_layout.tsx:108</code> ). Carried. |
| CQ-024 | Glue around the new rules untested<br><b>Low</b>            | Fixed                   | <code>session-manager.ts</code> was pulled out of <code>auth.ts</code> with 7 tests, including a 401 that arrives mid-refresh. A key-unavailable test exists for storage and outbox. <code>jobs.test.ts</code> covers a failing user, a bad zone, the catch-up and a deletion during a run. All three Given/When/Then cases from round 2 now exist. New gaps: CQ-042.                                                               |
| CQ-035 | Dead schema and small leftovers<br><b>Low</b>               | Fixed                   | <code>monthlySetAside</code> and <code>paginationQuerySchema</code> are removed. The FK check logs through <code>log()</code> ( <code>db/client.ts:32-38</code> ). <code>sms_imports</code> is kept on purpose: commit <code>d0c9863</code> says older databases hold real rows that the export should keep. The lazy cycle is still there (noted in CQ-041).                                                                       |
| CQ-025 | Live TLS block not in the repo<br><b>Low</b>                | Fixed server Unverified | The repo file now has the whole site: a port-80 block that only answers ACME and redirects, a TLS block with certbot's paths, HSTS, and 120 s for <code>/export</code> and <code>/ai/</code> ( <code>deploy/nginx-tick-taka.conf:7-78</code> ). The README uses <code>certbot certonly</code> , so certbot never rewrites the file.                                                                                                 |
| CQ-012 | Dependency advisories<br><b>Low</b>                         | Partially fixed         | <code>uuid</code> is pinned with <code>overrides</code> ( <code>package.json:20-22</code> ; <code>bun.lock</code> resolves <code>uuid@11.1.1</code> ). 5 advisories remain ( <code>_raw/audit.txt</code> ), each accepted with a reason ( <code>README.md:381-388</code> ). The CI audit job still fails every run ( <code>check.yml:19-28</code> ). Carried.                                                                       |

## 5. Findings

Grouped by category, sorted by severity. New findings are numbered from CQ-036, and carried findings keep their earlier IDs. Effort: S < 1 h, M < 1 day, L > 1 day.

### 5.1 Offline sync & data integrity

#### CQ-036 · A reply without `x-server-time` sets the phone's edit clock to 1970, and edits made until the next normal reply are lost

**High** · Offline sync / data integrity · Effort S · New · Reproduced (phone module and API)

##### Where

`apps/mobile/src/lib/http.ts:73`, `apps/mobile/src/lib/event-stream.ts:39`,  
`apps/mobile/src/lib/server-clock.ts:20-33`, `apps/api/src/lib/crud.ts:83-88`,  
`apps/mobile/test/server-clock.test.ts:41-45`

##### What's wrong

Both request paths call `noteServerTime(Number(response.headers.get("x-server-time")), ...)` on every reply. When the header is missing, `get()` returns `null`, and `Number(null)` is `0`, not `NaN`. The `Number.isFinite` guard therefore passes, and `offsetMs` becomes  $-(\text{sentAt} + \text{receivedAt})/2$ , about  $-1.79 \times 10^{12}$  ms. Because that is more than 1 s away from the saved value, it is also written to `AsyncStorage`. From then on `editTime()` returns the milliseconds since that reply: `-50` at first, about 60 000 a minute later.

Only the Hono app sets the header, so any reply Nginx writes itself lacks it. That includes the 502 while pm2 restarts the API (every deploy), a 504, and the 413 for an over-size body. `outbox-policy.ts:89-91` already expects proxy error pages to reach the phone. The outbox keeps retrying during an outage, so a phone with queued writes is very likely to see one.

34 call sites use `editTime()`, and most of them stamp a write at tap time. That includes 23 `PATCH updatedAt` stamps, timer start and stop (`time-tracking.tsx:94,134`, `running-timer-bar.tsx:73`), undo of task moves and assistant draft saves. The server keeps whichever row is newer and answers 200 with the old one (`crud.ts:85`), so the edit disappears at the next refresh and no message is shown. In the first moments the stamp is negative and the write is refused with a 400 instead. The next reply that carries the header repairs the offset, but writes already queued keep their 1970 stamps. If the app is killed while the server is still down, the saved bad offset is restored on the next start.

##### Evidence

```
// http.ts:68-73
const sentAt = Date.now();
const response = await http(input, { ... });
noteServerTime(Number(response.headers.get("x-server-time")), sentAt, Date.now());
// server-clock.ts:28-32
export function noteServerTime(serverTime: number, sentAt: number, receivedAt: number): void {
  {
    if (!Number.isFinite(serverTime)) return; // 0 passes
    offsetMs = serverTime - (sentAt + receivedAt) / 2;
    // crud.ts:85 – an older edit loses, silently
    if (editedAt !== undefined && editedAt < current.updatedAt) return current;
```

```

$ bun probe-clock.ts
after normal reply: editTime - now = 4950
header: null -> Number(header) = 0
after 502 reply: editTime() = -50 = 1969-12-31T23:59:59.950Z
saved offset: -1791319466210
$ bun test probe-lww.test.ts (createTestContext, in-memory)
POST /tasks -> 201
PATCH updatedAt=60000 -> 200 title now: Buy milk
PATCH updatedAt=-50 -> 400 {"error":{"code":"validation_error",...

```

The unit test for this case passes `Number.NaN` (`server-clock.test.ts:41-45`), which is not the value the real code produces.

### Why it matters

The app promises that offline edits are kept and replayed. Here a routine deploy, or any time the API is down while the phone has signal, quietly throws away renames, moves, status changes and undos made in that window. Timers started in it are saved as starting in 1970. Nothing tells the user, and nothing is logged on the server. This is not Critical only because the window is bounded by the next normal reply and because creates and deletes are not stamped.

### Recommendation

```

// http.ts and event-stream.ts: learn only from replies that carry the header
const header = response.headers.get("x-server-time");
if (header !== null) noteServerTime(Number(header), sentAt, Date.now());
// server-clock.ts: refuse impossible values, not only NaN
const EARLIEST = Date.UTC(2026, 0, 1);
if (!Number.isFinite(serverTime) || serverTime < EARLIEST) return;

```

Also clamp `editTime()` to be at least the last stamp it returned, so it can never go backwards. Replace the NaN test with one that passes `Number(new Headers().get("x-server-time"))`, and add one for a saved offset that is out of range.

### Effort

S

## CQ-038 · Setting a stuck write aside lets the writes that depend on it go first

**Medium** · Offline sync / ordering · Effort M · New

### Where

`apps/mobile/src/lib/outbox-queue.ts:89-98`, `247-254`, `284-292`, `apps/mobile/src/lib/outbox-policy.ts:64-79`, `apps/mobile/test/outbox-queue.test.ts:290-317`, `README.md` > Notes on decisions ("replays in order")

### What's wrong

Until this round the queue sent strictly in order. Now, after `STUCK_AFTER` (8) server faults other than 503, the head entry is parked and the loop moves on. The phone makes record ids itself (`newId()` in task, project, area, category, time-entry and other sheets), so the writes behind a stuck create often name that same record. If the parked write is `POST /tasks {id: T}`:

- a later `PATCH /tasks/T` gets 404, is classified `reject` and is removed for good, with a snackbar;
- a later `DELETE /tasks/T` gets 404, which `alreadyInWantedState` counts as `applied`;

- Retry then sends the create after both, so the task comes back without the edits, or comes back after the user deleted it.

A parked PATCH is mostly safe, because a newer PATCH lands first and the older one loses last-write-wins when retried.

#### Evidence

```
// outbox-queue.ts:250-254
entry.serverFailures = isServerFault(failure) ? (entry.serverFailures ?? 0) + 1 : 0;
if (entry.serverFailures >= STUCK_AFTER) {
  this.park(entry, error);
  continue; // next entry goes, whatever it refers to
}
// outbox-policy.ts:65-66
if (request.method === "DELETE" && status === 404) return true; // "applied"
```

The test for parking puts an unrelated write behind the poison one (PATCH /events/e1, then POST /tasks), so this case never runs.

#### Why it matters

The trigger is a server bug, not bad input, since CHECK violations are now 400s. When it happens, though, parking turns one failing write into a chain of lost or resurrected ones, which is the opposite of what it was added for. The user sees one "keeps failing" message and then a few "couldn't save" messages, with no hint that they are linked.

#### Recommendation

Park dependants with the write they depend on. When an entry is parked, collect the record ids it creates or edits (idsOfWrite in phone-writes.ts already extracts them). Park every later entry whose path or body names one of those ids, along with any entry queued later for the same ids. Retry and Discard act on the whole group, and discarding a parked create discards its group too. Add a test: stuck POST /tasks {id:T}, then PATCH /tasks/T, DELETE /tasks/T and one unrelated write. Only the unrelated write goes, and Retry sends the group in order.

#### Effort

M

### CQ-039 · Two ways the outbox can still lose writes without saying so

**Low** · Error handling / offline sync · Effort S · New

#### Where

apps/mobile/src/lib/outbox-queue.ts:142-149, 320-330, apps/mobile/src/features/widget/use-widget-sync.tsx:43-54

#### What's wrong

1. persist() chains every save with .catch(() => {}). If AsyncStorage refuses a write (disk full, a storage error), the queue carries on from memory, and a kill loses everything not yet sent. Nobody is told.
2. While the saved queue is unreadable (the CQ-028 fix), new writes are held only in memory, by design. useWidgetSync hands the widget's offline expenses to the outbox and then calls removePendingLogs. At that point the only durable copy is gone, and a kill before the key

becomes readable loses those expenses. The same short window exists at every start, before `load()` finishes.

#### Evidence

```
// outbox-queue.ts:320-329
private persist(): void {
  if (!this.loaded) return; // unreadable: memory only
  ...
  this.saving = this.saving.then(() => this.deps.save(state)).catch(() => {});
// use-widget-sync.tsx:45-48
const pending = await readPendingLogs();
for (const log of pending) send({ method: "POST", path: "/transactions", ... });
if (pending.length) await removePendingLogs(pending); // durable copy deleted here
```

#### Why it matters

"Log anything in under five seconds" is the spec's core promise, and the widget is the fastest way in. Both paths need an unusual condition (a storage failure, or a kill while the key can't be read), but when they happen the loss is silent.

#### Recommendation

In `persist()`, catch once, log, `notify()`, and expose a flag the sync bar shows. In `useWidgetSync`, await `outbox.flushed()` and delete the widget's copies only when the queue is loaded and not `savedUnreadable`. Otherwise leave them for the next start: each log carries a client id, so a repeat is refused as a duplicate rather than saved twice.

#### Effort

S

### CQ-037 · A Keystore read failure at start still costs the cached screens, and the next save can go to disk unencrypted

**Low** · Data integrity / security (client) · Effort S · New · [Unverified on device \(how often\)](#)

#### Where

`apps/mobile/src/lib/query-client.ts:75-89`, `node_modules/@tanstack/query-persist-client-core/build/modern/persist.js:32-38 (5.104.1)`, `apps/mobile/src/lib/encrypted-storage.ts:70-79`, `apps/mobile/src/lib/secure-storage.ts:95-106`, `apps/mobile/src/lib/session-manager.ts:66-76, 112-126`

#### What's wrong

The outbox now handles `KeyUnavailableError` correctly. The query-cache persister does not. `restoreClient` calls `secureStorage.getItem`, which throws, and TanStack's `persistQueryClientRestore` catches any error and calls `removeClient()`, which deletes `tt.query-cache`. The next throttled save then calls `setItem`. If the key still can't be read, encryption fails and the fallback writes the whole cache (balances, transactions, notes) in plain text until a later write seals it again. The only signal is a `console.warn`.

A related path: `refreshIfStale` awaits `save()` inside a `try` whose empty `catch` is meant for "offline". If a `SecureStore` write fails there, the new token exists only in memory, `SecureStore` keeps the old one, and `issuedAt` says "fresh". The old token retires 60 s after the new one is used, so the next cold start opens on the login screen.

## Evidence

```
// persist.js (TanStack) – any throw from restoreClient discards the cache
} catch (err) { ... await persister.removeClient(); throw err; }
// encrypted-storage.ts:71-78 – any cipher failure, including "key unavailable"
try { stored = SEALED_PREFIX + (await cipher.encrypt(value)); }
catch (error) { events.onPlainFallback?.(key, error); stored = value; }
```

### Why it matters

If the phone starts offline after a Keystore hiccup, the screens come up empty even though the data was on the phone. The plain-text fallback quietly undoes encryption at rest for a while. Both need a Keystore read failure, and how often that happens is unverified.

### Recommendation

Wrap the persister. On `KeyUnavailableError` in `restoreClient`, return `undefined` instead of throwing, and skip `persistClient` until a read succeeds. Limit the plain-text fallback to `tt.outbox`, the one value worth keeping at any cost, and skip the write for the cache. In `refreshIfStale`, handle a failed `save()` on its own: log it and reset `issuedAt` so the refresh is tried again.

### Effort

S

## 5.2 Maintainability & type safety

### CQ-020 · `quick-add.ts` keeps growing toward the ceiling (carried, narrowed)

Low · Maintainability · Effort M · Partially fixed

#### Where

`packages/shared/src/quick-add.ts` (649 lines; money parsing 258-407, task parsing 408-556)

#### What's wrong

The API half of this finding is done. `createToolRunner` went from 342 to 210 lines and `taskService` from 378 to 263, both by moving code along existing seams. `quick-add.ts` took two more fixes this round (b2d2d90 for multi-item lines, b29becc to narrow types) and is now 81% of the 800-line ceiling. It holds three parsers with separate vocabularies: money (wallet aliases, item separators, label numbers), tasks (priority, evening, someday, deadlines, recurrence) and time entries.

#### Why it matters

This is the capture path ("log anything in under five seconds"), it has the most edge cases, and it gets the most fixes. Splitting it before it reaches the ceiling is a move. After the ceiling it becomes a forced rewrite.

#### Recommendation

Move `parseMoney/parseMoneyList` and their constants to `quick-add-money.ts`, and `parseTask/takeRecurrence` and the task regexes to `quick-add-task.ts`. Keep `parseQuickAdd` and `describeDraft` in `quick-add.ts`, importing from the siblings by name, with no barrel.

#### Effort

M

## CQ-040 · The same month stepper is pasted in three screens, and icon buttons have no component

Low · Maintainability (owner rule) · Effort S · New

### Where

`apps/mobile/src/features/money/budgets-screen.tsx:60-79`, `money/money-calendar.tsx:67-86`, `plan/calendar-view.tsx:79-98`. Also 13 `className="h-12 w-12 items-center justify-center"` Pressables in 8 files.

### What's wrong

The owner's rule says markup repeated in three or more files becomes a shared component, with named variants. The 20-line previous/next month control (two Pressables, icons, labels, `addMonths`) is byte-identical in all three screens. The duplicate-block scan found 3 clusters across the 411 source files, and this is the only one that crosses three files. Bare icon buttons repeat the same 48 dp class string at 13 sites, and there is no `IconButton` in `components/ui`.

### Why it matters

Touch-target and accessibility fixes have to be made once per copy. `eb45efa` ("make the last small targets thumb-sized") changed `calendar-view` and `money-calendar` separately, which shows the cost.

### Recommendation

Extract `components/ui/month-stepper.tsx` (`<MonthStepper month onChange />`) by moving the markup verbatim, and add `components/ui/icon-button.tsx` with a named `size` option instead of class strings.

### Effort

S

## CQ-022 · Client JSON is still cast without checks, and the cache buster never moves (carried, narrowed)

Low · Type safety · Effort M · Partially fixed

### Where

`apps/mobile/src/lib/api.ts:49-53`, `58-70`, `apps/mobile/src/app/_layout.tsx:108`, `apps/mobile/src/lib/http.ts:73`

### What's wrong

The non-null half is done well: `0 !` in source, the rule is an error, and a `defined(value, what)` helper names what was missing. `unwrap` and `send<T>` still return `response.json()` as `T`. Typed RPC covers a fresh response, but data restored from the persisted cache is never re-checked, and `buster` has stayed `"1"` through two rounds of response changes (additive so far, such as `previousDueAt`). CQ-036 is the same pattern at a smaller scale: a header turned into a number without a check.

### Why it matters

The error boundary limits the damage. The first non-additive change to a cached shape, though, will crash a screen on start-up until the user taps "Reset cached data".

### Recommendation

Derive `buster` from a constant you bump in the same commit as any response change (or from the app version), and parse the few headers and bodies the phone reads outside RPC with zod.

### Effort

M

## CQ-041 · Small leftovers from this round's edits

Low · Maintainability / docs · Effort S · New

### Where / what

- `apps/api/src/middleware/auth.ts:9-21`: `requireAuth`'s doc block now sits above `LEGACY_TOKENS_UNTIL`. Editors show it on the constant, and `requireAuth` has no doc of its own.
- `apps/mobile/src/lib/outbox-policy.ts:81`: the doc line for `mayHaveReachedServer` is stranded above `STUCK_AFTER`'s block, 17 lines from its function (`:98`).
- `apps/mobile/src/lib/auth.ts:112` exports `expireSession`, which nothing imports. It is the only unused value export. 14 exported types are also referenced nowhere.
- `apps/api/src/jobs/offsite.ts:37` logs `(error as Error).message` rather than `errorFields(error)` like every other job.
- `apps/api/src/db/sessions.ts:107-112`: `touch()` runs `UPDATE ... SET expires_at` on every authenticated request for any refreshed session, because `replaces` is never cleared. The comment at `:36` says reads should not turn into writes. It is cheap in WAL mode, but it is a write transaction per request.
- `README.md:124-125` promises "undo for every change" from the assistant, but `start_timer`, `stop_timer` and `update_settings` record none (`assistant/actions.ts:131-148`, `216-221`).
- The lazy import cycle `db/schema/time.ts:11 ↔ money.ts:11` is still the only one in the repo. It is harmless.

### Recommendation

Move the two doc blocks back to their functions. Delete `expireSession`. Use `errorFields`. Skip `shorten` when the replaced session is already short, for example by clearing `replaces` after the first `shorten`. Either word the README as "undo for most changes" or add undos for the timer and settings actions.

### Effort

S

## 5.3 Testing, tooling & dependencies

## CQ-042 · The new glue is tested, but some tests use inputs the real code never passes

Low · Testing · Effort M · New

### Where

`apps/mobile/test/server-clock.test.ts:41-45`, `apps/mobile/test/outbox-queue.test.ts:290-317`, `apps/mobile/src/lib/sync-changes.ts`, `query-client.ts:82-89`, `use-widget-sync.tsx`, `apps/api/src/modules/ai/ask.ts` (62.68% lines; 114-187 uncovered)

### What's wrong

Round 2's test gaps are closed, and the new tests read well as Given/When/Then. Two of them, though, model the input more cleanly than production does. "A missing header" is tested with `Number.NaN`, while `http.ts` passes `Number(null) = 0` (CQ-036). The stuck-write test puts an unrelated write behind the poison one (CQ-038). Some paths have no test at all: `pullChanges`, the persister restore on a key failure (CQ-037), and the widget hand-over (CQ-039). In the API, most of the "ask my data" tools in `ask.ts` (lines 114-187) never run in tests. In mobile, `http.ts` is at 46% of functions and `quick-add-requests.ts` at 72.9% of lines.

### Why it matters

The two bugs this round found sit exactly where a test replaced the real input with an ideal one.

### Recommendation

- Given a reply with no `x-server-time`, when `request()` returns, then `editTime()` is within 1 s of the previous value.
- Given `POST /tasks {id:T}` is stuck, when `PATCH /tasks/T` and an unrelated write are queued, then only the unrelated write is sent.
- Given `storageKey()` rejects at start, when the cache is restored, then `tt.query-cache` is still in storage and nothing is written in plain text.
- Given a fake `OpenAI` that calls each `ask` tool once, when `/ai/ask` runs, then each answer uses only default-currency rows.

### Effort

M

## CQ-012 · Accepted advisories leave the CI audit job permanently red (carried, narrowed)

**Low** · Security / dependencies · Effort S · Partially fixed

### Where

`.github/workflows/check.yml:19-28`, `README.md:381-388`, `_raw/audit.txt`

### What's wrong

`uuid` is now patched (11.1.1 through `overrides`, and the only consumer outside the tooling, `xcode`, uses `require('uuid')`, which 11.x still provides). The other 5 advisories (braces and node-forge high; postcss-selector-parser, decode-uri-component and esbuild moderate) are accepted with a reason each, and all sit in build or CLI tooling. The CI job still runs plain `bun audit` under `continue-on-error: true`, so it fails on every run, and a new advisory looks exactly like today's.

### Why it matters

The README's list of accepted advisories is good practice. The CI signal doesn't use it yet.

### Recommendation

Fail the job only on advisories that are not on an allow-list of the five GHSA ids, through `bun audit`'s own `ignore` or `JSON` option if 1.3.11 has one ( [Unverified](#) ), or else a short `grep` over its output. Then drop `continue-on-error`.

### Effort

S

## 6. Strengths: keep these

- **Fixes that follow the root cause, in layers.** CQ-027 was fixed in three places: the schema refuses bad zones, reads heal values already stored, and the job loop isolates each user, catches the tick and logs unhandled rejections. Any one of those layers would have stopped the crash.
- **Commit discipline.** All 42 commits are Conventional Commits, each one logical change, with a `Refs: CQ-0xx` trailer and a body that explains why. None carry co-author or agent lines. `d0c9863` explains why `sms_imports` stays instead of silently ignoring that part of the recommendation.
- **Testable cores pulled out of React Native.** `session-manager.ts` (from `auth.ts`), `phone-writes.ts`, `widget-pending.ts`, `server-clock.ts` and `move-undo.ts` follow the outbox-policy pattern: pure rules, injected storage, fast tests.
- **Careful session design.** The refresh grace starts only once the new token is used, so a refresh reply lost on the way to the phone signs nobody out. Logout ends both tokens. The legacy branch has a fixed end date and a test that proves it.
- **The assistant boundary got smaller and safer.** A handler table with one function per action, ULID-only ids, strict tool schemas with an enum for `action`, money changes as drafts with the exact request shown to the user, and deletions that always wait for a tap.
- **Migrations that repair before they constrain,** with a test that seeds the rows older builds let through. A failed open names the user (as an HMAC tag) in the log.
- **Type hygiene.** 0 non-null assertions, 1 justified `any`, 0 `@ts-ignore`, strict plus `noUncheckedIndexedAccess`, and `defined()` failing loudly with a name.
- **Unchanged strengths.** One SQLite file per user, integer money with CHECKs, zod at every boundary, typed RPC, no secrets in git, no barrel files, no file over 800 lines, 0 TODO/FIXME, and backups that check their own integrity, now with an off-site hook.

## 7. Action plan

### Refactoring roadmap

| When              | Items                                                                                                                                                                                                                                                                                                                |
|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Now (this week)   | CQ-036: learn the clock only from replies with the header, refuse impossible values, and never let <code>editTime()</code> go backwards. Ship this before the next deploy. · CQ-038: park dependants with their stuck write. · CQ-039: surface save failures and make the widget hand-over wait for a durable queue. |
| Next (this month) | CQ-042: replace the idealised test inputs and add the four cases. · CQ-037: keep the cache when the key can't be read, and limit the plain-text fallback to the outbox. · CQ-041: small leftovers. · CQ-040: <code>MonthStepper</code> and <code>IconButton</code> .                                                 |
| Later             | CQ-020: split <code>quick-add.ts</code> into money and task siblings before it reaches the ceiling. · CQ-022: versioned cache buster and zod at the few untyped reads. · CQ-012: allow-list the accepted advisories in CI.                                                                                           |

## Prioritised table

| Order | ID     | Title                                                                               | Severity | Effort |
|-------|--------|-------------------------------------------------------------------------------------|----------|--------|
| 1     | CQ-036 | Header-less reply sets the edit clock to 1970; edits in the window are lost         | High     | S      |
| 2     | CQ-038 | Parked stuck write lets dependent writes go first                                   | Medium   | M      |
| 3     | CQ-039 | Silent outbox save failures; widget hand-over drops its durable copy                | Low      | S      |
| 4     | CQ-042 | Tests use inputs the real code never passes                                         | Low      | M      |
| 5     | CQ-037 | Key failure at start discards the cache; plain-text fallback                        | Low      | S      |
| 6     | CQ-041 | Small leftovers (orphaned docs, dead export, per-request UPDATE, README undo claim) | Low      | S      |
| 7     | CQ-040 | Month stepper in 3 files; no IconButton                                             | Low      | S      |
| 8     | CQ-020 | <code>quick-add.ts</code> at 649 lines and growing                                  | Low      | M      |
| 9     | CQ-022 | Client JSON casts; cache buster never bumped                                        | Low      | M      |
| 10    | CQ-012 | CI audit job always red                                                             | Low      | S      |

## 8. Appendix

### A. Raw command output (trimmed)

```
$ bunx biome check .
Checked 523 files in 334ms. No fixes applied.          exit 0
$ bun run typecheck
@tick-taka/shared typecheck: Exited with code 0
@tick-taka/api typecheck: Exited with code 0
@tick-taka/mobile typecheck: Exited with code 0
$ bun run test
@tick-taka/shared test: 247 pass, 0 fail, 519 expect() (13 files)
@tick-taka/mobile test: 233 pass, 0 fail, 683 expect() (43 files)
@tick-taka/api test:    209 pass, 0 fail, 759 expect() (31 files) [8.72s]
$ bun test --coverage (All files: % Funcs | % Lines)
api      88.18 | 94.49  lowest: ai/ask.ts 62.68, schema/time.ts 79.72, categories/routes.ts 79.25
shared   82.95 | 96.50  tiki.ts 69.09, quick-add.ts 90.00
mobile   93.47 | 93.79  http.ts 46.15 funcs, quick-add-requests.ts 72.90, plan-notifications.ts
80.82
$ bun audit
braces <=3.0.3          high      via tailwindcss, expo, react-native, react-native-worklets
node-forge <=1.4.0      high      via expo
postcss-selector-parser moderate via tailwindcss
decode-uri-component    moderate via expo-router
esbuild <=0.24.2        moderate via drizzle-kit (api), tailwindcss
5 vulnerabilities (2 high, 3 moderate)          exit 1
$ bunx expo export --platform android
Android Bundled 24909ms apps/mobile/index.ts (2837 modules) · index-....hbc (7.7MB)  exit 0
$ git log --format=%s df29d67..HEAD | grep -vE
'^((feat|fix|refactor|test|chore|docs|perf|build|ci)(\(...\)))?: '
(no output: 42 of 42 match)
$ git log --format=%b df29d67..HEAD | grep -iE 'co-author|claude|anthropic'
(no output)
```

### B. Code health counts (source only: apps/api/src, apps/mobile/src, packages/shared/src)

| Pattern                          | R1        | R2  | R3  | Notes / locations                                                                                                                                        |
|----------------------------------|-----------|-----|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| any                              | 1         | 1   | 1   | api/src/lib/crud.ts:45, with a justified biome-ignore                                                                                                    |
| @ts-ignore / @ts-expect-error    | 0         | 0   | 0   |                                                                                                                                                          |
| biome-ignore                     | 4         | 7   | 7   | crud.ts:44; message-bubble.tsx:24,65,211; chat-composer.tsx:66; use-notification-scheduler.ts:107; habit-list.tsx:116. All give a reason.                |
| as X casts (AST, excl. as const) | ~187<br>* | 135 | 144 | *R1 counted by regex. Top: resource-routes.ts 10, crud.ts 9, assistant/tools.ts 9, outbox-policy.ts 6, agent.ts 5, insights/summary.ts 5. as const : 95. |
| as unknown as                    | 1         | 1   | 1   | mobile/src/lib/receipts.ts:47 (RN FormData file)                                                                                                         |

| Pattern                                                        | R1     | R2                 | R3                | Notes / locations                                                                                                                                                                                                                    |
|----------------------------------------------------------------|--------|--------------------|-------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Non-null !                                                     | 44     | 60                 | 0                 | Rule is error outside tests. <code>defined()</code> is used at 16 sites.                                                                                                                                                             |
| TODO / FIXME / HACK                                            | 0      | 0                  | 0                 | Source and tests                                                                                                                                                                                                                     |
| <code>console.*</code>                                         | 5      | 5                  | 6                 | <code>log.ts:7,8</code> (the API sink). Mobile: <code>sync-changes.ts:61</code> , <code>secure-storage.ts:54,59</code> , <code>use-notification-scheduler.ts:89</code> .<br><code>db/client.ts</code> no longer logs to the console. |
| <code>.catch(() =&gt; {})</code> / empty <code>catch {}</code> | 20 / 2 | 27 / 2             | 24 / 2            | Mostly best-effort calls (haptics, notifications, Google sign-out). Notable: <code>outbox-queue.ts:329</code> (CQ-039). Empty catches: <code>agent.ts:85,89</code> (display-only JSON parse).                                        |
| Runtime import cycles                                          | 0      | 1                  | 1                 | <code>db/schema/time.ts</code> ↔ <code>money.ts</code> (lazy FK thunks, safe)                                                                                                                                                        |
| Files over 800 lines                                           | 0      | 0                  | 0                 | Largest source: <code>shared/quick-add.ts</code> 649. Largest test: <code>api/test/money.test.ts</code> 548.                                                                                                                         |
| Barrel index files                                             | 0      | 0                  | 0                 | The index files are entry points ( <code>api/src/index.ts</code> , <code>mobile/index.ts</code> ) or Expo Router routes                                                                                                              |
| Duplicate 8-line blocks                                        | n/a    | 10                 | 3                 | Method this round: 8 normalised non-trivial lines, at least 200 characters, distinct file sets. Don't compare with R2 directly. The one that crosses 3 files is CQ-040.                                                              |
| Exports referenced nowhere                                     | n/a    | 2 values, 10 types | 1 value, 14 types | <code>expireSession</code> ( <code>mobile/lib/auth.ts:112</code> ). Types: store types ( <code>JobRunStore</code> , <code>SessionStore</code> , <code>UsageTotalStore</code> , <code>SessionManager</code> ) and schema aliases.     |
| Committed secrets / data files                                 | 0      | 0                  | 0                 | Only the two <code>.env.example</code> files are tracked. No key patterns found.                                                                                                                                                     |

## C. Largest functions and files (TypeScript AST)

| Lines | Function                                                         | R2  |
|-------|------------------------------------------------------------------|-----|
| 297   | TaskSheet ( <code>tasks/task-sheet.tsx:34</code> )               | 292 |
| 285   | TransactionSheet ( <code>money/transaction-sheet.tsx:35</code> ) | 284 |
| 263   | taskService ( <code>api tasks/service.ts:38</code> )             | 378 |
| 261   | InsightsScreen ( <code>review/insights-screen.tsx:43</code> )    | 260 |
| 231   | RecurringForm ( <code>money/recurring-sheet.tsx:50</code> )      | 229 |
| 216   | useAssistant ( <code>assistant/use-assistant.ts:66</code> )      | 209 |

| Lines | Function                                                | R2  |
|-------|---------------------------------------------------------|-----|
| 210   | createToolRunner (assistant/tools.ts:151)               | 342 |
| 210   | WeeklyReview (review/weekly-review.tsx:26)              | 211 |
| 209   | SafeToSpendWidget (widget/safe-to-spend-widget.tsx:128) | n/a |
| 207   | PlanHome (plan/plan-home.tsx:24)                        | 205 |

| Lines | Largest files (src + SQL)                           |
|-------|-----------------------------------------------------|
| 649   | packages/shared/src/quick-add.ts (R2 583)           |
| 484   | packages/shared/src/recurrence.ts                   |
| 428   | api/drizzle/0004_constraints.sql (R2 379)           |
| 360   | api/src/modules/ai/assistant/tools.ts (R2 556)      |
| 336   | mobile/src/features/widget/safe-to-spend-widget.tsx |
| 335   | mobile/src/lib/outbox-queue.ts                      |
| 332   | api/drizzle/0000_init.sql                           |
| 330   | mobile/src/features/tasks/task-sheet.tsx (R2 324)   |
| 319   | mobile/src/features/money/transaction-sheet.tsx     |
| 315   | packages/shared/src/schemas/money.ts                |

All under the 800-line ceiling. `api/src/modules/tasks/service.ts` went from 435 to 300 lines.

## D. Requirement checklist (engineering commitments from the docs)

| Commitment (source)                                                       | Status  | Evidence                                                                                                                                       |
|---------------------------------------------------------------------------|---------|------------------------------------------------------------------------------------------------------------------------------------------------|
| TypeScript strict everywhere (PLAN, owner rules)                          | Met     | <code>tsconfig.base.js</code><br><code>n: strict</code> and<br><code>noUncheckedIndexed</code><br><code>Access</code> ; mobile<br>repeats both |
| 800-line ceiling; no barrels (owner rules)                                | Met     | Appendix B and C;<br>quick-add.ts is the one<br>to watch (CQ-020)                                                                              |
| Markup in 3+ files is a shared component (owner rules)                    | Not met | CQ-040                                                                                                                                         |
| Conventional Commits, no attribution, one change per commit (owner rules) | Met     | 42 of 42; Appendix A                                                                                                                           |
| Money as integers (PLAN)                                                  | Met     | <code>*_minor</code> integer<br>columns with CHECKS                                                                                            |
| Per-user data isolation (README)                                          | Met     | user-registry.ts, user-<br>scope.ts; the usage<br>report no longer opens<br>other users' DBs                                                   |

| Commitment (source)                                     | Status      | Evidence                                                                                                                                                                                                                |
|---------------------------------------------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Offline queue never loses writes (PLAN Phase 7, README) | Partial     | CQ-036, CQ-038, CQ-039                                                                                                                                                                                                  |
| Service stays up for all users                          | Met         | CQ-027 fixed; job loop and process guard tested                                                                                                                                                                         |
| Login rate limit, 5 per 15 min per IP (PLAN)            | Met in code | <code>auth/routes.ts:34;</code><br>production<br><code>TRUST_PROXY</code><br><b>Unverified</b>                                                                                                                          |
| Nightly backups, 14 kept, off-site copy (PLAN, README)  | Met in code | <code>backup.ts</code> , <code>offsite.ts</code> ;<br><code>BACKUP_OFFSITE_CMD</code> on the server<br><b>Unverified</b>                                                                                                |
| AI cap and off switch (PLAN Phase 6)                    | Met         | Cap checked before every call; owner's report reads <code>users.db</code>                                                                                                                                               |
| No AI feature saves records without confirmation (spec) | Partial     | A documented decision. Money changes are drafts and deletions wait for a tap. Task, habit, timer and settings changes apply at once with Undo (IMPLEMENTATION_PLAN.md:20-22). This is a product call for the UX report. |
| Account and data deletion (privacy page)                | Met         | Also clears <code>ai_usage_totals</code> ; deletion during a job run is now safe                                                                                                                                        |
| Every phase ends with tests passing (PLAN)              | Met         | <code>check.yml</code> on push to main and on PRs                                                                                                                                                                       |

## E. File inventory

| Workspace       | Source files | Source lines  | Test files               | Test lines   |
|-----------------|--------------|---------------|--------------------------|--------------|
| apps/api        | 105          | 9,927         | 35 (31 test + 4 helpers) | 5,022        |
| apps/mobile     | 288          | 21,747        | 43                       | 2,806        |
| packages/shared | 18           | 3,270         | 13                       | 1,486        |
| <b>Total</b>    | <b>411</b>   | <b>34,944</b> | <b>91</b>                | <b>9,314</b> |

Round 2 had 390 source files with 33,032 lines and 73 test files with 7,373 lines. Migrations are still 0000 to 0005. 0004 gained the repair block, and the session and usage-total tables in users.db are created in code.

## F. Previous-findings tally

| Status                | IDs                                                                |
|-----------------------|--------------------------------------------------------------------|
| Fixed (13)            | CQ-016, 019, 024, 025, 027, 028, 029, 030, 031, 032, 033, 034, 035 |
| Partially fixed (3)   | CQ-012, 020, 022 (carried, narrowed)                               |
| Not fixed / Regressed | none                                                               |

## G. Probe scripts (run from `_cq_tmp/`, then deleted)

```
// probe-clock.ts (CQ-036, phone side) – imports apps/mobile/src/lib/server-clock.ts
await restoreServerClock(memoryStorage);
noteServerTime(t0 + 5000, t0, t0 + 100); // normal reply
noteServerTime(Number(new Headers().get("x-server-time")), t1, t1 + 100); // Nginx 502
console.log(editTime(), saved["tt.server-clock"]); // -50, -1791319466210

// probe-lww.test.ts (CQ-036, server side) – run with bun test from apps/api
const ctx = await createTestContext();
const t = await ctx.request("POST", "/tasks", { title: "Buy milk" }); // 201
await ctx.request("PATCH", `/tasks/${t.body.id}`, { title: "Buy oat milk", updatedAt: 60_000 });
// 200, title still "Buy milk"
await ctx.request("PATCH", `/tasks/${t.body.id}`, { title: "x", updatedAt: -50 }); // 400

// scan.ts / cycles.ts / dup.ts / unused.ts – TypeScript AST counts, Tarjan SCC over
// relative and @tick-taka/shared imports (type-only imports excluded), 8-line windows,
// and exported names grepped across apps/* and packages/* (src and tests).
```